Desarrollo de software

Desarrollo en sistemas de IA agéntica

Participación en el SDLC, controles de GitHub y responsabilidad humana



La IA participa en el desarrollo

La evolución amplía lo que podemos delegar

01

Sugerir

Código, explicaciones y recomendaciones.

02

Actuar

Explorar el repositorio, planificar cambios y abrir un PR.

03

Supervisar

El desarrollador guía, revisa evidencias y valida resultados.

Asistente y agente

Asistente

Responde a una solicitud

Sugiere código y explica resultados.

El usuario elige y ejecuta el siguiente paso.

La respuesta devuelve el control al usuario.

Agente

Mantiene un objetivo

Decide pasos intermedios y utiliza herramientas.

Actúa sobre artefactos persistentes del repositorio.

Itera con feedback de checks y reviews.

Un asistente propone. Un agente puede proponer y actuar dentro del workflow.

El agente entra al workflow de GitHub

01 **Tarea**

Objetivo y criterios

02 **Branch**

Cambios y commits

03 **Pull Request**

Propuesta y contexto

04 **Checks y reviews**

Evidencia y revisión

05 **Validación**

Decisión según políticas

06 **Merge**

Cambio aceptado

Branches, commits, PR y reviews hacen visible el trabajo del agente.

Una dependencia vulnerable: dos enfoques

Con un asistente

El usuario consulta cómo actualizar

Recibe comandos recomendados.

Obtiene un checklist de riesgos.

Crea la branch, modifica archivos y abre el PR.

Con un agente

El objetivo inicia una contribución

Crea una branch y actualiza la dependencia.

Modifica el lockfile y abre un PR con su plan.

Espera checks y feedback, y ajusta el cambio.

Ejemplo ilustrativo: agent/bump-dep-2026-04-03

El ciclo Plan, Act, Evaluate

Plan

Define el enfoque y los criterios de éxito.

Act

Ejecuta cambios dentro del alcance permitido.

Evaluate

Contrasta el resultado con señales del sistema.

El ciclo continúa hasta cumplir los criterios o escalar a una persona.



Plan: una intención inspeccionable

Scope

Qué cambiará

Paquete, archivos y límites del trabajo.

Success criteria

Cómo sabremos que funcionó

Resultado esperado y evidencia necesaria.

Fallback

Qué ocurre si falla

Rollback o ruta de escalamiento.

El plan queda en un Issue, la descripción del PR o un checklist revisable.

Act: ejecución dentro de límites

1

Repositorio

Contexto y permisos definidos.

2

Branch

Cambios de archivos y commits delimitados.

3

Pull Request

Propuesta revisable y respuesta al feedback.

La ejecución acotada evita cambios directos y no controlados en la branch por defecto.

Evaluate: evidencia del sistema

Checks técnicos

¿El cambio funciona?

Builds, tests, linting, workflow runs y status checks.

Code review

¿El cambio es apropiado?

Requested changes, review comments y approvals.

Seguridad

¿Persisten riesgos?

Code scanning, SARIF, secret scanning, dependency alerts y push protection.

La confianza del agente en su respuesta no sustituye la evaluación.

Caso completo: actualizar una dependencia

Plan	Identifica el paquete, los archivos y el resultado esperado.
Act	Crea la branch, actualiza dependencia y lockfile, genera commits y abre el PR.
Evaluate	CI, tests, seguridad y revisión humana comprueban el resultado.

Si falla un workflow o persiste la vulnerabilidad: revisar el plan, modificar y reevaluar, o escalar.

GitHub registra el trabajo y aplica controles

System of Record

Conserva lo que ocurrió

Repositories, branches, commits y Pull Requests.

Issues, Discussions y review history.

Workflow runs y artifacts.

Control Plane

Condiciona lo que puede ocurrir

Reglas para proponer y aceptar cambios.

Reviews y checks obligatorios.

Límites para ejecuciones, secrets y deployments.

La efectividad de los controles depende de su configuración y de los permisos.

Controles de GitHub para contribuciones

Control	Qué controla	Importancia para agentes
Pull Requests	Propuesta antes del merge	Revisar y discutir el cambio
Required Reviews	Revisión antes del merge	Supervisión humana
Required Status Checks	Evidencia de CI	Evaluación como política
CODEOWNERS	Reviews según archivos	Especialistas en áreas sensibles
Rulesets / Branch Protection	Políticas sobre branches	Bloqueo de merges inseguros
Environments	Deployments y secrets	Aprobaciones para accesos sensibles

Estos mecanismos solo son obligatorios cuando la configuración y los permisos lo establecen.

GitHub Actions y mínimo privilegio

Permisos conservadores

Por defecto

Workflow tokens con permisos read-only cuando sea posible.

Por job

Permisos superiores solo donde resultan necesarios.

Para lo sensible

Environments y approvals para secrets y deployments.

El alcance real del agente también depende de sus tokens y credenciales.

Tres puntos de intervención humana

Workflows

Aprobar la ejecución

En determinados PR, una persona utiliza “Approve and run workflows”.

Environments

Autorizar la continuación

Un job espera la aprobación de reviewers antes de acceder a recursos protegidos.

CODEOWNERS

Involucrar responsables

Rutas como .github/workflows/ o infra/ solicitan revisión especializada.

Las políticas de revisión obligatoria convierten estos puntos en controles exigibles.

Control de un PR con un security fix

1. **PR visible**
   Cambio, motivo y plan.
2. **Owners adecuados**
   Revisión de áreas sensibles.
3. **Evidencia**
   Workflows y required checks.
4. **Políticas**
   Merge bloqueado hasta cumplirlas.
5. **Acceso protegido**
   Secrets del Environment sujetos a aprobación.



La responsabilidad sigue siendo humana

La ejecución puede delegarse.

Las personas y equipos responden por el resultado.

Definen

La tarea y los criterios.

Configuran

Permisos y controles.

Revisan

Resultados y evidencias.

Aprueban

Los cambios que se aceptan.

Riesgos y mitigaciones

Ejecución sin plan	PR con diff, sin explicar el alcance.	Plantilla con plan y revisión antes del merge.
Permisos excesivos	Agente o credenciales con privilegios innecesarios.	Least privilege, Environments y restricciones de ejecución.
Contexto oculto	Solo aparece el resultado final.	Registrar plan, supuestos, decisiones y workflow runs.
Confianza ciega	Aceptar el cambio porque CI pasó.	Combinar checks con owners, reviews y aprobaciones según riesgo.

Trazabilidad para reconstruir lo sucedido

¿Qué cambió?

¿Por qué cambió?

¿Quién lo aprobó?

¿Qué evidencia existía?

¿Qué ocurrió después?

Contribución

PR, commits, comentarios y approvals.

Ejecución

Workflow runs, logs, test reports y artifacts.

Seguridad

Alertas, eventos de push protection y audit logs disponibles.

Audit trail mínimo de una contribución

01 **Goal**

Objetivo en Issue o PR

02 **Plan**

Enfoque inspeccionable

03 **Changeset**

Branch y commits acotados

04 **Evidence**

Runs y artifacts

05 **Human judgment**

Review y aprobación

06 **Outcome**

Merge, revert o escalamiento

Ante una regresión, el registro debe permitir revisar alcance, owners y evidencia.

Contributor Model: evaluar la contribución

El Pull Request es la unidad de revisión

Sospecha excesiva

Rechazar el cambio solo porque lo escribió una IA.

Confianza excesiva

Aceptarlo solo porque lo produjo una automatización.

Mismos estándares: problema resuelto, scope apropiado, checks, owners, arquitectura y políticas.

Checklist para revisar un PR de un agente

01	**Intent**	¿Objetivo claro y plan visible?
02	**Scope**	¿Los archivos modificados corresponden al plan?
03	**Evidence**	¿Checks aprobados y logs o artifacts necesarios?
04	**Ownership**	¿Los owners revisaron las áreas sensibles?
05	**Policy**	¿Cumple rulesets, branch rules y Environments?
06	**Fallback**	¿Hay rollback y criterio de escalamiento?

Modelo completo de una contribución

01

Objetivo

El agente interpreta la tarea.

02

Plan

Scope, éxito y fallback.

03

Act

Branch, cambios, commits y PR.

04

Evaluate

Checks, seguridad y juicio humano.

Cumple: continúa según políticas. No cumple: itera. No puede resolverlo: escala.

Comprensible Acotada Revisable Conforme a políticas Reconstruible

El rol del desarrollador se amplía

Definir objetivos y decidir qué se acepta

Guía al agente

Con objetivos y planes claros.

Configura límites

Con permisos y políticas.

Supervisa acciones

Con evidencia y trazabilidad.

Valida resultados

Con criterio técnico y responsabilidad.

El agente participa en el SDLC bajo los controles del workflow.

Continuidad del aprendizaje

Arquitectura e integración

Developing Agent Architecture and SDLC Integration

learn.microsoft.com/en-us/training/modules/
design-agent-architecture-integration/

Herramientas y entornos

Tooling, MCP, and Agent Execution Environments

learn.microsoft.com/en-us/training/modules/
agent-tooling-mcp-execution-environments/

Una buena contribución es comprensible, acotada, revisable, conforme a políticas y reconstruible.